SSRF with Filter Bypass via Open Redirection

Platform: PortSwigger Web Security Academy
Vulnerability: Server-Side Request Forgery (SSRF)
Difficulty: Practitioner
Lab Status: Practical Lab Write-up

1. Overview

Server-Side Request Forgery (SSRF) is a vulnerability that allows an attacker to manipulate a server into sending HTTP requests to unintended destinations. These destinations may include internal services, administrative interfaces, or other restricted resources.

In this lab, an SSRF protection mechanism restricts the destinations that can be accessed. However, an open redirection vulnerability on a trusted application endpoint can potentially be abused to bypass this restriction.

2. Lab Objective

The objective is to exploit the application's open redirection functionality to bypass the SSRF destination filter and access a restricted internal resource within the authorized lab environment.

3. Methodology

1. Browse the application and locate the product stock-checking functionality.
2. Intercept the stock-check request using Burp Suite Proxy.
3. Identify the parameter responsible for specifying the URL that the server fetches.
4. Test whether the application validates the destination URL and rejects direct requests to restricted internal resources.
5. Identify an application endpoint that performs open redirection using a user-controlled destination parameter.
6. Determine whether the redirect endpoint can be used as an intermediate destination to reach the restricted internal resource.
7. Modify the stock-check request to use the trusted redirect endpoint, then observe the application's response.
8. If the request reaches the intended internal resource, complete the lab's specified objective.

4. Technical Explanation

The vulnerability results from the interaction between two security weaknesses:

- **SSRF:** The server fetches a URL supplied through a request parameter.
- **Open redirection:** A trusted application endpoint redirects requests to a destination controlled by the requester.

If the SSRF filter validates only the initial URL, it may approve a trusted application endpoint without adequately validating the destination reached after redirection.

This creates an opportunity to bypass destination restrictions through a trusted redirect.

5. Security Impact

Successful exploitation may allow an attacker to:

- Access internal application endpoints.
- Reach administrative interfaces not directly exposed to external users.
- Interact with internal services accessible from the server.
- Bypass network or application-level restrictions, depending on the environment.

The actual impact depends on the server's network access, permissions, and the sensitivity of the internal resources.

6. Remediation

- Validate the final destination of every outbound request, including after redirects.
- Disable automatic redirects where they are unnecessary.
- Restrict outbound requests through a strict allowlist of approved hosts and ports.
- Resolve hostnames and validate destination IP addresses against internal and restricted ranges.
- Prevent open redirect vulnerabilities by validating redirect destinations.
- Apply network-level egress filtering to limit access to sensitive internal services.
- Log and monitor suspicious outbound requests.

7. Conclusion

This lab demonstrates how an open redirection vulnerability can undermine an SSRF protection mechanism. Validating only the initial URL is insufficient when the server follows redirects. Effective protection requires destination validation throughout the request process and appropriate network restrictions.

Reference: PortSwigger Web Security Academy — Server-side request forgery (SSRF)

https://portswigger.net/web-security/ssrf